

Security Logging and Evidence Retention Procedure

COIT13236 | Security monitoring and incident response

SEC-04 | Version 1.0 | 9 September 2026

Owner: IT Administrator | Approval: _____ | Effective date: _____

Collect usable security records, detect logging failures and preserve evidence for investigations. The IT Administrator maintains the collector and restricts access to operational logs and incident evidence.

Operating baseline: approve the proposed thresholds and response targets before activation. Review each semester and after a significant incident or system change.

Required log sources

Source	Required records
pfSense	Relevant firewall rule decisions, system events, administrative and remote-access authentication where configured
Samba AD	Authentication outcomes, account lockouts and account or group changes from validated audit sources
Linux file server	Selected Samba operations and failures; host audit events for local protected-file changes
Servers and workstations	Login outcomes, privileged actions, security service and audit interruptions where supported
Central monitoring service	Rule triggers, delivery attempts, acknowledgements, escalations and configuration changes

Record each source hostname, role, address, installed version, configured log destination, parser, owner and last successful test. Preserve raw records alongside normalised fields. Mark missing identities or fields as unknown; do not infer success from an absent failure event.

Transport and time

Use a restricted management network and encrypted forwarding where supported. Native pfSense remote syslog uses UDP and is not encrypted; keep it on a trusted isolated path or protected VPN and retain local logs to cover loss. Configure the selected log categories explicitly. [1]

Synchronise sources and collector to approved time services. Preserve original timestamps and timezone and normalise centrally to UTC. Display incident timelines in Australia/Brisbane with the offset. Alert on measured drift exceeding 60 seconds and document corrections.

Retention and evidence preservation

Proposed retention schedule

Record type	Retention and control
Routine security logs	90 days searchable; archive until 365 days from event time
Local source logs	Target at least 7 days subject to capacity; alert before rotation can remove unforwarded records
Incident evidence	Until 12 months after closure or longer under an active hold; owner reviews before disposal
Delivery and acknowledgement history	365 days; preserve with evidence for an associated incident

These are project operating values for approval, not statutory retention claims. Suspend deletion for active incidents and holds. Archive expiry is measured from the event date; do not add another 365 days after the searchable period.

Evidence handling steps

1. Create an incident ID and restrict its evidence directory to authorised responders. Record collector, source system, collection method, original timezone and collection time.
2. Export relevant raw logs and configuration state, including events before and after the incident. Preserve volatile session information where practical. Document gaps and collection errors.
3. Retain originals without editing. Calculate a SHA-256 hash for each exported file and store a manifest separately under restricted access. Hashes support integrity checking; they do not prove the source was truthful.
4. Use working copies for analysis. Log every transfer or access with person, time, purpose, file identifier and hash verification result. Protect originals with immutable storage where available.
5. Apply a retention hold, back up evidence to a separate protected location and test retrieval. Release holds only with recorded approval; record disposal date, scope, method and authoriser.

Health checks and validation

Operational health checks

- Use a heartbeat or synthetic test at least every 5 minutes for critical sources. Raise High if two expected heartbeats are missed; event silence alone may be legitimate.
- Check collection queues, parser failures, archive jobs and available space daily. Raise Medium at 80 percent storage use and High at 90 percent or when logging stops.
- Restrict collector administration and record changes. Keep logging credentials separate from ordinary user accounts and monitor deletion or audit shutdown.
- During collector failure, preserve source logs, restore collection, reconcile gaps and explicitly document any UDP messages that cannot be recovered.

Acceptance tests

Test	Pass condition
Generate a labelled event on every registered source	Raw and parsed copies arrive with correct attribution and time
Stop a test heartbeat or forwarding path	Health alert reaches the administrator under SEC-03
Retrieve an archived test record	Record is readable and linked to the correct source and period
Copy evidence and verify its manifest	Hash matches; transfer is recorded
Attempt access as an ordinary test user	Evidence and collector administration are denied
Exercise retention on disposable records with a hold	Expired eligible records removed; held evidence preserved

Evidence register: Incident ID / file ID / source / collected by / time and timezone / SHA-256 / storage location / access history / hold status / approved disposal date. Store detailed manifests with evidence, not in general email.

References

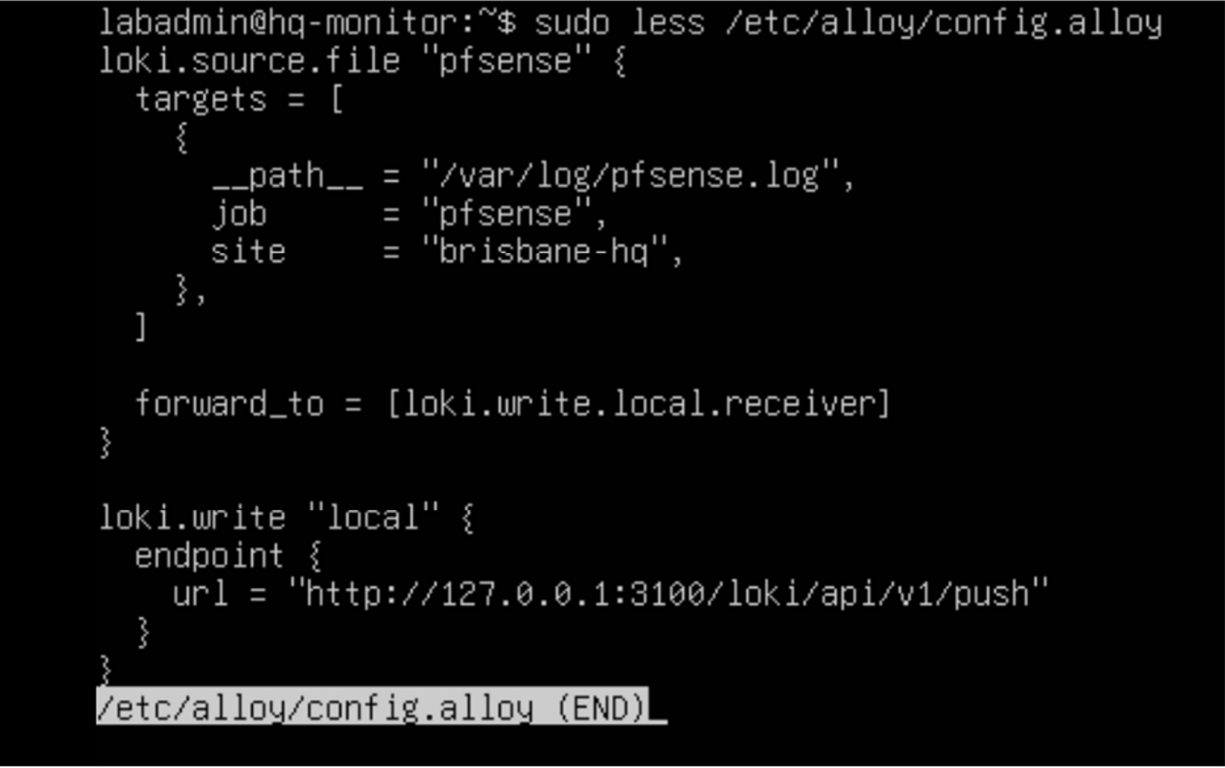
[1] Netgate. Remote Logging with Syslog.

<https://docs.netgate.com/pfsense/en/latest/monitoring/logs/remote.html> Accessed 9 September 2026.

Screenshot evidence appendix

These figures record selected laboratory observations. They support the tested functions described in this artefact. Proposed policies, untested controls and organisational approval remain separate from the pictured results.

Figure E1 Alloy collection configuration



```
labadmin@hq-monitor:~$ sudo less /etc/alloy/config.alloy
loki.source.file "pfsense" {
  targets = [
    {
      __path__ = "/var/log/pfsense.log",
      job      = "pfsense",
      site     = "brisbane-hq",
    },
  ]

  forward_to = [loki.write.local.receiver]
}

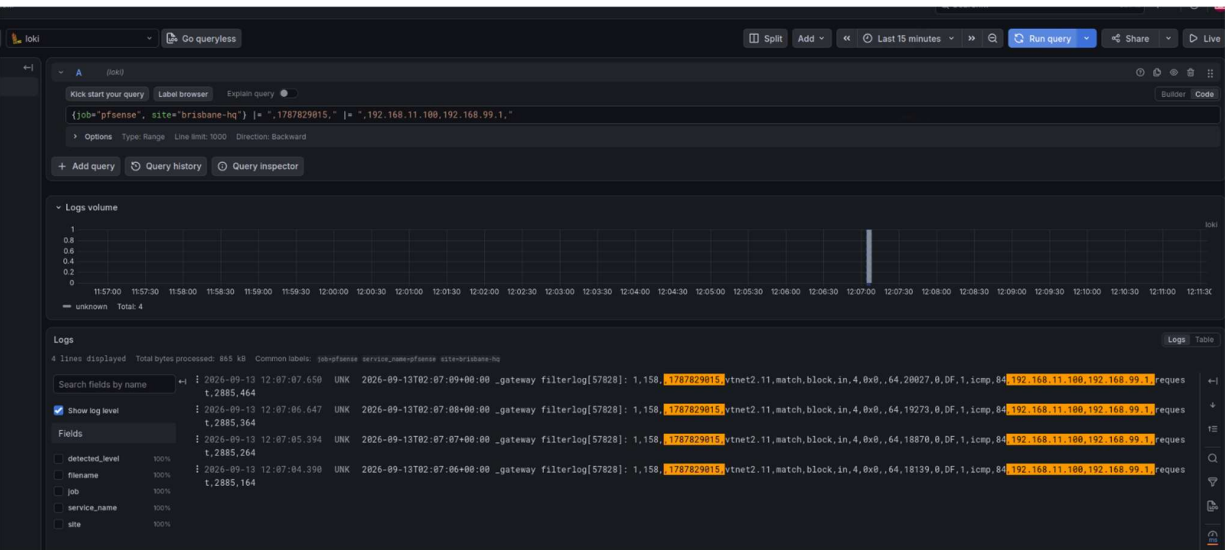
loki.write "local" {
  endpoint {
    url = "http://127.0.0.1:3100/loki/api/v1/push"
  }
}
/etc/alloy/config.alloy (END)
```

The configuration reads `/var/log/pfsense.log`, applies the `pfsense` and `Brisbane HQ` labels and forwards records to Loki. It does not establish an enforced retention period.

Source evidence: `evidence/HQ_MONITOR_Alloy_Pipeline.png`

Screenshot evidence continued

Figure E2 Correlated firewall records



Grafana retrieves four matching R06 records for source 192.168.11.100 and destination 192.168.99.1. This establishes the demonstrated collection and retrieval path.

Source evidence: evidence/T01_Grafana_R06_Four_Blocks.png